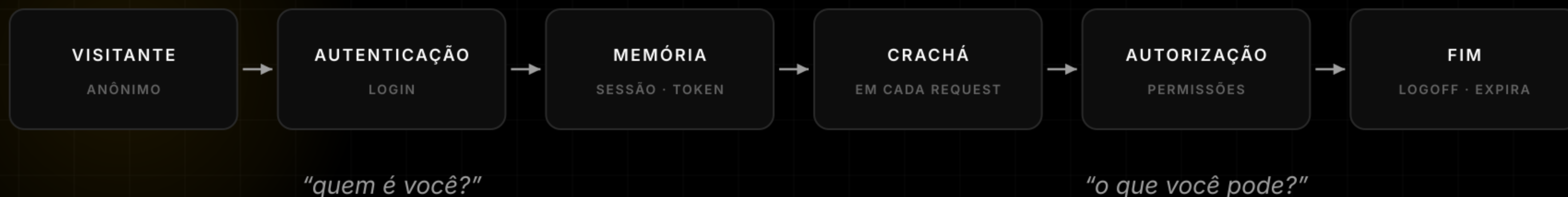


A história de um login

O FLUXO DE AUTH



Vamos acender uma etapa por vez, do visitante ao logoff.

Mundo sem auth: todo mundo é admin

VISITANTES ANÔNIMOS

- lista de usuários
- perfil de outra pessoa
- apagar dado alheio

REQUEST

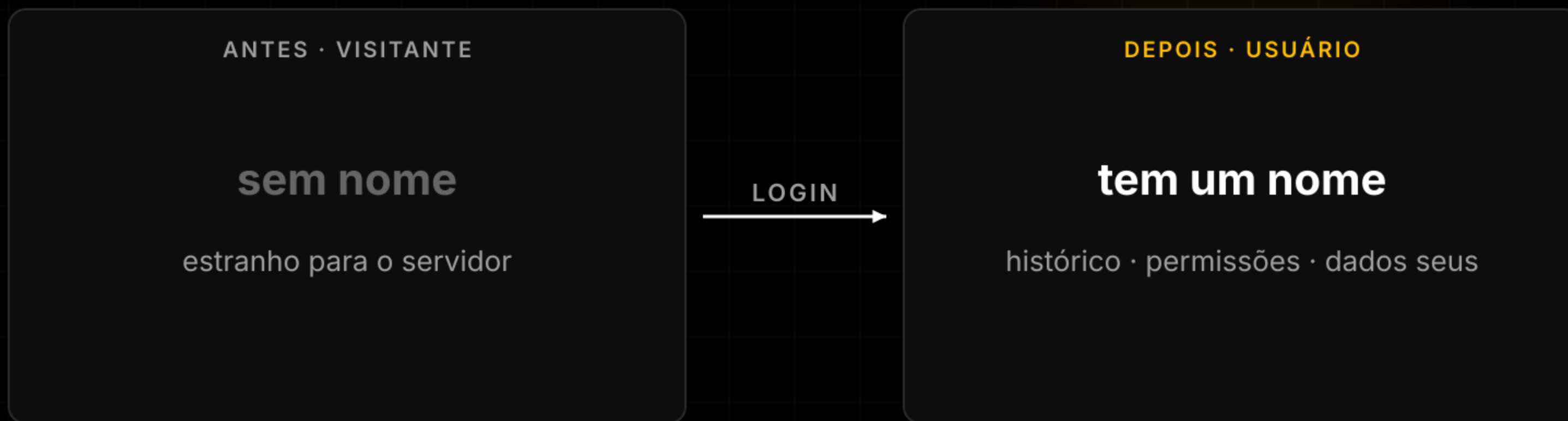
SERVIDOR · SEM AUTH

responde igual para todos

sem filtro · sem discriminação
privacidade zero · alteração livre

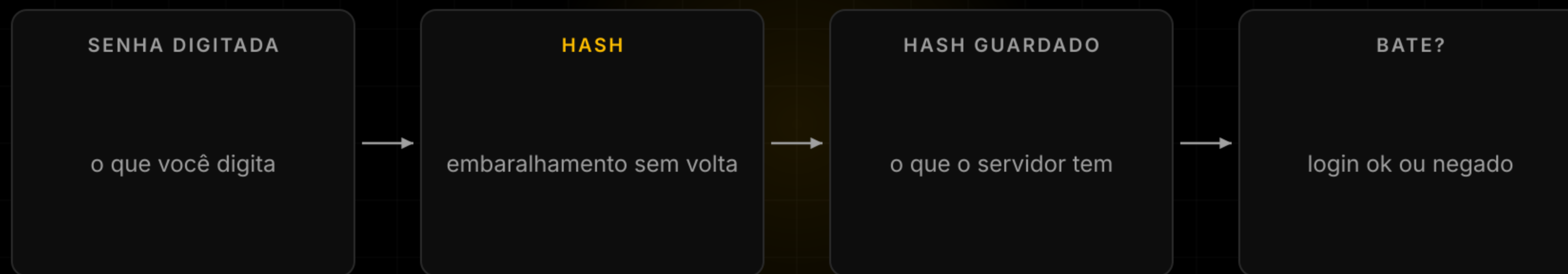
Sem camada de controle, quem chega primeiro manda.

Login: de visitante a alguém específico



Login é se identificar e provar quem você é.

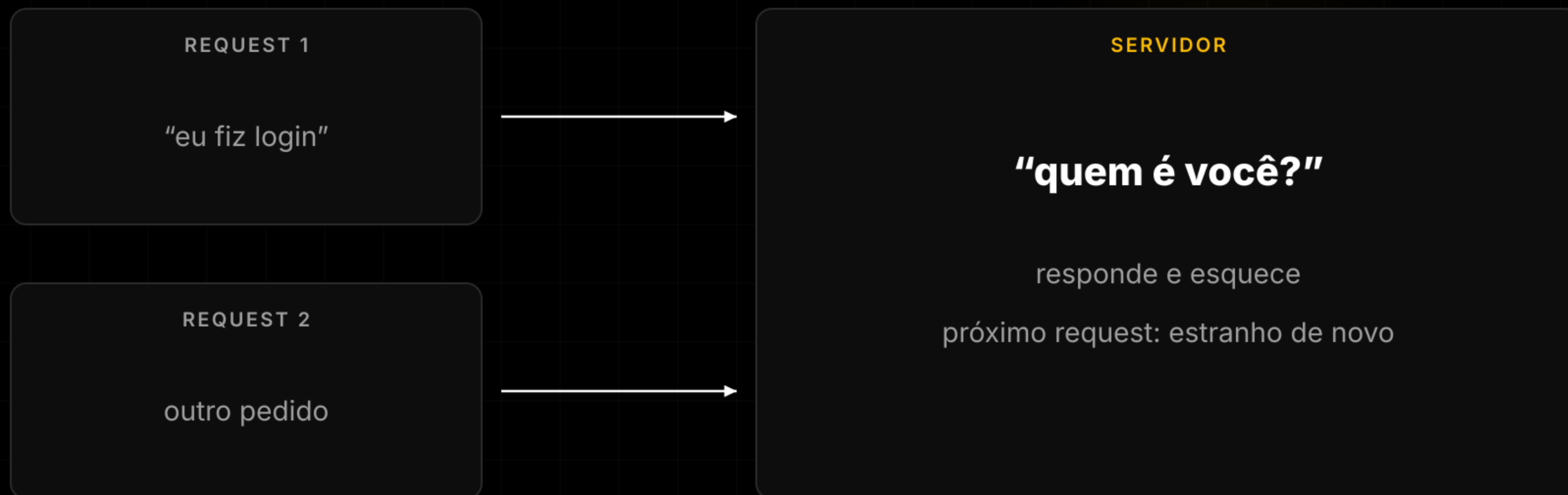
Senha vira hash. O servidor compara



O servidor não guarda a senha. Guarda o hash dela.

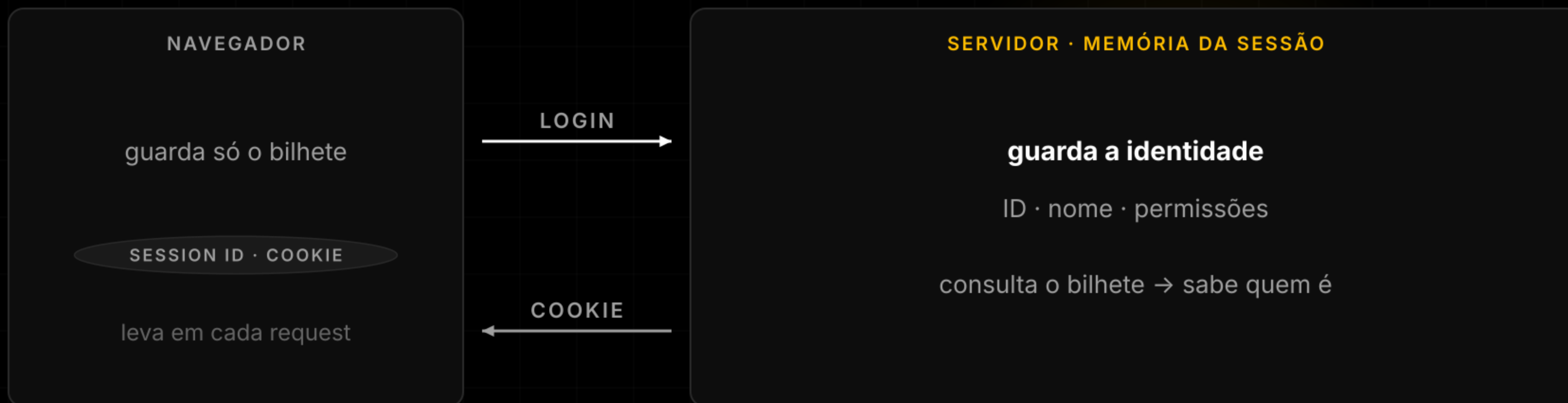
Hash é embaralhamento que não tem volta.

HTTP não tem memória



Cada request é tratado como se fosse o primeiro.

Sessão: o guarda-volumes do servidor



A memória mora no servidor. O navegador só carrega o ID.

Token: o crachá que você carrega



Ler, qualquer um lê. Forjar a assinatura, não.

Sessão vs token: onde a memória mora

SESSÃO

- memória no servidor
- navegador leva o bilhete
- dá para invalidar na hora
- simples de controlar

TOKEN

- memória no cliente
- crachá carrega a identidade
- bom com vários servidores
- servidor só precisa ler

Os dois resolvem o mesmo problema: lembrar entre requests.

Auth são duas perguntas, não uma

AUTENTICAÇÃO

Quem é você?

login · senha · token · sessão



AUTORIZAÇÃO

O que você pode?

papel · recurso · permitido ou negado

Autenticado não é autorizado a tudo.

Permissão por papel

	VER	EDITAR	APAGAR	GERENCIAR
ADMIN	✓	✓	✓	✓
USER	✓	✓	✗	✗
GUEST	✓	✗	✗	✗

Papel é um grupo com um conjunto de permissões.

Admin pode tudo. User o que é dele. Guest só o público.

Permissão por recurso: esse item é seu?



Mesmo papel, recurso alheio: bloqueado.

Remover auth é abrir o servidor

ANTES · PROTEGIDO

- ✓ verifica quem é
- ✓ verifica o que pode
- ✓ bloqueia o que não deve

REMOVE

DEPOIS · ABERTO

- ✗ verificação comentada
- ✗ protegido vira público
- ✗ qualquer um manda

Pergunte: o que para de ser verificado se eu remover isso?

Logoff, expiração e crachá roubado

LOGOFF



crachá destruído

sessão apagada · token invalidado

EXPIRAÇÃO



prazo de validade

sem prazo = risco eterno

ROUBO



alguém se passa por você

servidor obedece o crachá

Auth é um ciclo: login é o começo, logoff e expiração são o fim.